Revalidación posterior a correcciones

Semgrep OSS se ejecutó nuevamente el 21/10/2026 sobre el árbol de trabajo derivado del commit **5f15b3b**. La ejecución terminó correctamente y produjo un JSON independiente para comparar los resultados antes y después de las correcciones.

11	6	0	546
coincidencias iniciales	coincidencias posteriores	missing-integrity restantes	reglas ejecutadas

Comparación y decisión

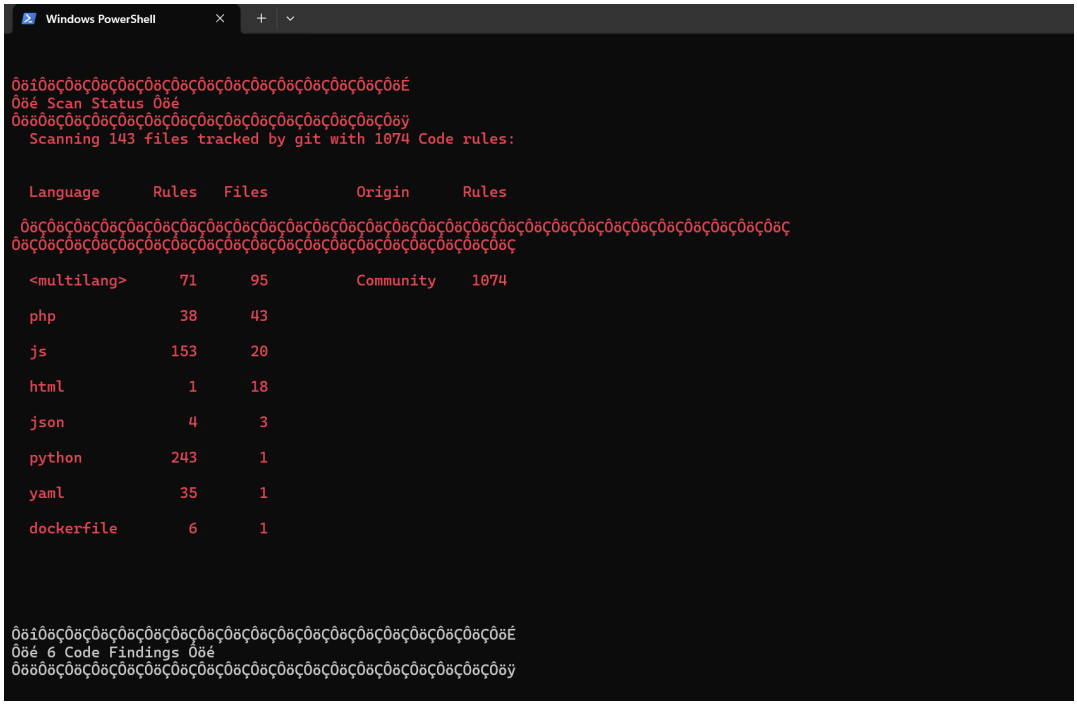
Control	Antes	Después	Decisión
Integridad de recursos	8 alertas por Lucide remoto sin integrity.	0 alertas; los iconos se sirven desde un archivo local.	Cerrado.
Ejecución de procesos	passthru con comando construido como texto.	proc_open recibe una lista de argumentos y no invoca un shell.	Mitigado; Semgrep conserva 1 alerta por el uso del sink.
Ruta de caché	1 alerta tainted-filename.	Permanece la coincidencia; la clave continúa reducida a SHA-256 y raíz fija.	Falso positivo documentado.
Borrado de archivos	1 alerta unlink-use.	Permanece la coincidencia; realpath y UPLOAD_ROOT restringen el destino.	Mitigado; mantener pruebas de rutas.
Formularios de acceso	No se informaba CSRF porque no declaraban POST.	3 alertas de una regla para plantillas Django.	No aplicable: HTML estático, API PHP y autenticación Bearer sin cookies.

Conclusión SAST

La debilidad confirmada de cadena de suministro quedó corregida. Las seis coincidencias posteriores no representan seis vulnerabilidades explotables: tres son la regla Django aplicada fuera de contexto, dos conservan controles compensatorios ya revisados y una corresponde a una utilidad CLI que ahora ejecuta PHP sin construir una línea de shell.

Evidencia y límites de cobertura

Captura 2. Resumen de la segunda ejecución de Semgrep proporcionada por el equipo.



Trazabilidad

Artefacto	SHA-256
informes-sast-post/semgrep-post.json	1A11FF607656121E675DE1EE7D31A0BCAA7BD6CD18B2A402ED27A87478FDDE59
informes-sast-post/semgrep-post-terminal.txt	F48B522056EB3C56A94DE8D0000C3432D4EDBC84792F7F5BAF20073CCFE66E63

Limitaciones

La ejecución registró 1 advertencia de análisis parcial sobre el Dockerfile. Además, Semgrep indicó que limitó el alcance a archivos seguidos por Git: el nuevo archivo local de iconos todavía no estaba versionado y el ajuste final del nombre de la configuración Apache ocurrió después de esta ejecución. El cierre formal debe identificar el commit final y, si se exige cobertura exacta de todo el corte, repetir Semgrep una vez versionados esos cambios.